PÓSTER DE MINIINVESTIGACIÓN

¿Es seguro el código que generan los asistentes de programación con IA?

Evelin Monroy Anselmo · Ingeniería Informática, 5.º semestre · Software · Inteligencia artificial · Ciberseguridad · Noviembre 2026

1 PREGUNTA DE INVESTIGACIÓN

¿Qué tan seguro es el código que generan los asistentes de programación con inteligencia artificial y qué deben hacer los estudiantes de Ingeniería Informática al usarlos?

2 JUSTIFICACIÓN

Cada vez más estudiantes, incluida yo, usamos asistentes de IA para programar tareas y proyectos, por ejemplo APIs con FastAPI conectadas a MySQL.

En mi ruta de carrera definí como prioridad la ciberseguridad aplicada al desarrollo de software. Si el código sugerido trae vulnerabilidades y no sé detectarlas, mis proyectos pueden exponer la información de sus usuarios.

Responder esta pregunta me ayuda a usar la IA con criterio y no solo por comodidad.

≈ 40 %

de los programas generados por Copilot en escenarios de riesgo resultaron vulnerables (Pearce et al., 2022).

3 FUENTES ACADÉMICAS Y SÍNTESIS PROPIA

FUENTE 1 · ESTUDIO EXPERIMENTAL · IEEE S&P 2022

Pearce, H., Ahmad, B., Tan, B., Dolan-Gavitt, B., & Karri, R. (2022). *Asleep at the keyboard? Assessing the security of GitHub Copilot's code contributions.* 2022 IEEE Symposium on Security and Privacy (SP). IEEE. https://arxiv.org/abs/2108.09293

Síntesis: Los autores pidieron a GitHub Copilot completar 89 escenarios relacionados con las debilidades de software más peligrosas de la lista CWE Top 25 de MITRE y obtuvieron 1,689 programas. Al analizarlos, cerca del 40 % tenía vulnerabilidades. También observaron que el contexto influye: si el código previo ya tiene errores, la IA tiende a sugerir código con fallas. Mi conclusión es que la IA aprende de código público que también contiene errores, así que no garantiza seguridad.

FUENTE 2 · ESTUDIO CON USUARIOS · ACM CCS 2023

Perry, N., Srivastava, M., Kumar, D., & Boneh, D. (2023). *Do users write more insecure code with AI assistants?*. Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (CCS '23), 2785–2799. ACM. https://doi.org/10.1145/3576915.3623157

Síntesis: Este estudio de la Universidad de Stanford comparó a personas que programaron con y sin un asistente de IA. Quienes usaron el asistente escribieron soluciones inseguras con más frecuencia en cuatro de cinco tareas y, además, creían con más seguridad que su código era seguro. Los participantes que confiaron menos en la IA y ajustaron mejor sus instrucciones obtuvieron código con menos vulnerabilidades. Para mí, el riesgo no es solo técnico: también está en la confianza excesiva de quien programa.

Lo que dicen juntas: Las dos fuentes coinciden en que los asistentes de IA pueden producir código vulnerable y en que el riesgo aumenta cuando se acepta sin revisar. La primera lo demuestra analizando el código de la herramienta; la segunda, observando a personas reales. Juntas sugieren que la IA es útil como apoyo, pero la responsabilidad de la seguridad sigue siendo de quien desarrolla.

4 MÉTODO PROPUESTO

1. Elegir 6 tareas comunes de mis proyectos con FastAPI y MySQL: inicio de sesión, búsqueda por ID, registro de usuarios, subida de archivos, actualización de datos y eliminación de registros.
2. Generar cada tarea con un asistente de IA usando la misma instrucción y guardar el código obtenido.
3. Revisar el código con una herramienta de análisis estático para Python (Bandit) y con una lista de verificación basada en OWASP Top 10 y CWE Top 25.
4. Registrar en una tabla qué vulnerabilidades aparecen (por ejemplo, inyección SQL o contraseñas sin cifrar) y cuántas tareas quedan seguras.
5. Aplicar una encuesta breve a compañeros de la carrera sobre qué tanto confían en el código que genera la IA.

5 LIMITACIONES

- La muestra sería pequeña (6 tareas y un grupo reducido de compañeros), así que los resultados no se pueden generalizar.
- Los modelos de IA cambian rápido; los estudios revisados usaron versiones de 2021 a 2023 y los resultados actuales podrían ser distintos.
- Las herramientas de análisis estático pueden marcar falsos positivos u omitir fallas, por eso se necesita también revisión manual.
- Solo revisé dos fuentes; para conclusiones más sólidas hace falta consultar más estudios recientes.

6 SIGUIENTE PASO

Realizar la prueba piloto durante el mes 3 de mi plan de formación (calidad y despliegue), documentar los resultados en un reporte y agregar a mis proyectos una lista de revisión de seguridad antes de publicar cualquier código generado con IA.